

ENTERPRISE SECURITY ASSESSMENT LAB

AD NETWORK SECURITY METHODOLOGY REPORT

Phase 3 - Validating password weakness after NetNTLMv2 capture

Report Section	Phase 03 - Offline Hash Cracking with Hashcat
Project Area	Internal Network and Active Directory Security Assessment
Environment	Private Windows AD lab - Kali Linux, Windows Server, Windows endpoint
Prepared For	GitHub Portfolio Documentation
Document Type	Individual methodology PDF with redacted evidence

Authorized lab documentation only. Sensitive credential material, hashes, passwords, and replication output have been redacted before publication.

1. Executive Summary

This report documents **Offline Hash Cracking with Hashcat** as part of the AD Network module in the Enterprise Security Assessment Lab. The section is written as a professional, portfolio-safe methodology report that explains the testing objective, workflow, evidence, tool usage, sanitized output, security risk, remediation guidance, and GitHub publication requirements.

Objective: Demonstrate that captured NetNTLMv2 material becomes dangerous when user passwords are weak enough to be cracked offline using a wordlist-based attack in the private lab.

MITRE / Framework Mapping	T1110.002 - Brute Force: Password Cracking
Testing Scope	Authorized private Active Directory lab only
Evidence Handling	Screenshots embedded with necessary redaction; raw hashes and secrets are not included

2. Methodology and Workflow

The methodology below is designed to show a controlled penetration-testing workflow rather than random tool execution. Each step supports a specific assessment goal and produces evidence that can be reviewed safely in a public portfolio.

- Take captured NetNTLMv2 material from the Responder phase.
- Use Hashcat mode 5600, which is appropriate for NetNTLMv2.
- Use the wordlist only in the lab to validate weak password risk.
- Record only a redacted screenshot for portfolio publication.
- Use the cracked credential only for the next authorized validation step.

Command / Workflow Used

```
# Example Hashcat mode for NetNTLMv2
hashcat -m 5600 captured_ntlmv2_hashes.txt /usr/share/wordlists/rockyou.txt

# Show cracked result in a sanitized local-only workflow
hashcat -m 5600 captured_ntlmv2_hashes.txt --show
```

Sanitized Output Style

```
Hash type: NetNTLMv2
Attack mode: Dictionary/wordlist
Status: Cracked in lab
Recovered credential: <REDACTED_USER>:<REDACTED_PASSWORD>
```

3. Evidence Mapping and Screenshot Explanation

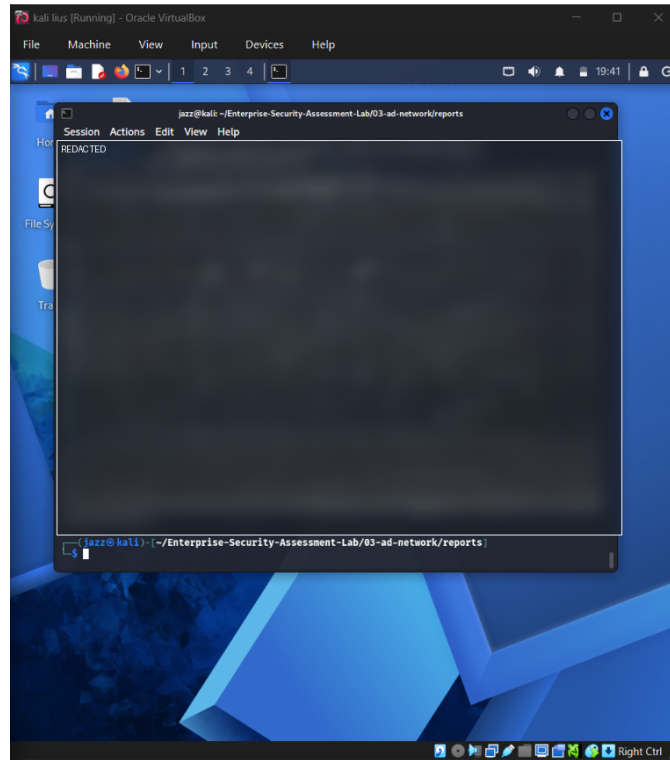


Figure - Hashcat NetNTLMv2 cracking evidence

This screenshot documents offline cracking of captured NetNTLMv2 material. Sensitive hash and cracked password material are redacted.

4. Technical Interpretation

The evidence is interpreted in the context of a private AD lab. The screenshot proves execution of the relevant technique or validation step, while the sanitized command and output blocks show how the result should be presented without exposing raw credential material.

What the evidence proves	The lab phase for Offline Hash Cracking with Hashcat was executed and documented.
What it does not prove	It does not indicate testing of any public, third-party, or production network.
Publication status	Safe for GitHub after redaction of sensitive values.

5. Risk Analysis

Offline cracking avoids normal account lockout protections because the password guessing occurs locally against captured challenge/response material. If the password is weak or common, the attacker can obtain a valid domain credential without repeated online logon attempts.

Real-World Impact Categories

- Credential exposure or credential reuse risk
- Lateral movement or privilege escalation potential depending on account rights
- Domain visibility and attack path discovery in internal environments
- Operational and detection gaps if monitoring does not cover the relevant Windows, Kerberos, SMB, or LDAP events

6. Recommended Remediation

- Use long passphrases and block common passwords.

- Deploy password filters that prevent known leaked passwords.
- Disable LLMNR/NBT-NS to reduce hash capture opportunities.
- Apply MFA where possible, especially for remote and administrative access.
- Monitor for suspicious authentication and credential misuse after potential exposure.

7. GitHub Redaction and Publication Guidance

- Publish only redacted evidence. Do not upload raw hashes, password material, ticket files, DCSync output, or secretsdump text dumps.
- Keep this report under 03-ad-network/reports/methodology/ and keep raw tool output in a private working folder unless fully sanitized.
- Use placeholders such as , , , and in public documentation.
- Confirm the screenshot file name in the README matches the repository file name exactly, including case, hyphens, and extension.

Do Not Upload

```
*.hash
*_hashes.txt
responder logs with raw NetNTLMv2
kerberoast_hashes.txt
secretsdump output
DCSync dumps
cracked-password files
unredacted BloodHound collection ZIPs if they expose sensitive names
raw command history containing passwords
```

8. Conclusion

The **Offline Hash Cracking with Hashcat** phase demonstrates a structured and evidence-based AD testing workflow. The report explains the purpose of the test, shows sanitized evidence, connects the activity to real-world risk, and provides practical remediation guidance. This makes it suitable for a professional cybersecurity GitHub portfolio.